Security, privacy, trust and responsible AI

A practical explanation of the app, its execution safeguards and its remaining roadmap. **AI assists with HR work; an AI recommendation is not permission to act.**

Capability review: 8 October 2026. Examples are illustrative, not customer results.

How to read this guide	What the label means
Implemented	A capability exists in the reviewed application. Availability still depends on the user's access and relevant configuration.
Configuration required	The control or integration boundary exists, but approved policies, authority, provider setup or operational evidence are prerequisites. This is not a claim that a live service is enabled.
Roadmap	Additional capability or assurance work is not present as the complete function described. It is proposed improvement, not a delivery commitment.

Organization isolation and scoped access

IMPLEMENTED

Client records are scoped to the current organization. Named people and registered agents receive defined permissions through access groups and scopes. Signing in is not permission to see every client's records or use every tool.

Temporary access and professional authority

IMPLEMENTED

Temporary access can expire. Organization ownership or administration does not automatically grant legal, medical, privacy or payroll specialist authority.

Business example
A hiring manager can track onboarding progress without automatically receiving medical findings. A documentation agent is not allowed to change payroll simply because it recommends that change.

Assurance boundary: This guide is a capability explainer, not a penetration-test report, regulatory certification or confirmation of every live tenant's configuration.

Privacy and protected records

The aim is to collect only what is permitted, disclose only what is authorized, and retain information under reviewed rules.

Sensitive-data policies, retention and holds

CONFIGURATION REQUIRED

Sensitive collection and use require the applicable approved policies. Missing approval or uncertain classification can block processing. Retention controls and legal holds govern cleanup; draft policy proposals do not authorize live handling.

Controlled uploads and quarantine

IMPLEMENTED

Private file handling and scan gates protect access to sensitive uploads. Quarantined files cannot simply be opened or approved to finish a checklist. Scan availability and results depend on the configured scanner. Malware safety is separate from authenticity.

Restricted AI evidence

IMPLEMENTED

Domain evidence builders apply authorization and minimization or redaction before model disclosure. Unclassified text is not automatically safe. Context history is metadata-only: it does not store prompts, answers, documents or contact details.

Reviewed context-history cleanup

CONFIGURATION REQUIRED

Automatic pruning needs an approved retention rule. Unfinished, recent, oversized or otherwise unsafe-to-delete chains are preserved. Applicable legal holds can pause cleanup across a tenant. Protected audit evidence is retained independently.

Business example
A privacy reviewer approves a retention rule, but a legal hold is active. The app preserves the affected history instead of deleting it on age alone. An old unfinished attempt is not treated as completed just to make cleanup easier.

Roadmap: Broader consolidated compliance evidence packs and obligation-to-control coverage reporting would make oversight easier. Existing audit and review records are not a complete certification package.

The agent harness and testing harness

The agent harness controls execution. The testing harness checks whether that behavior works under the conditions tested. Neither is an extra AI model.

Implemented execution control	Meaning for business users
Named agent and tool scope	The app checks the registered executor and permitted action. Agent identity or permissions supplied in a request are not accepted as authority.
Live gates and approvals	Sensitive or consequential actions remain subject to current policy, permission, authority and evidence checks.
Bounded AI requests	AI input and output requests have budgets. Mandatory evidence is not silently removed to fit an oversized request.
Checkpoints and effect records	Recovery uses recorded work and safe dispatch controls rather than blindly repeating completed external actions.
Metadata investigation	Personal history and separately authorized operator history show attempts, steps, filters, correlation links and older pages. History does not authorize a business retry.

Business example
An external operation times out. If repeating it could create a duplicate change and the outcome cannot be confirmed, the app stops for reconciliation. A supported idempotent operation may be retried through its existing safeguards.

UAT, controlled demos and regression checks

IMPLEMENTED

The UAT Test Center, guided scenarios, controlled demo paths and automated checks support assurance. Observed evidence, simulations, blocked work and manual steps must remain distinguishable. A passed test covers the tested behavior, not all possible failures.

Business example
A test confirms that an authorized reviewer can perform an action and an unauthorized reviewer is denied. A simulated payroll exchange does not prove a real payroll provider was updated.

Roadmap: Extend the harness with systematic answer-quality benchmarks, fairness scenarios and provider-specific conformance tests before expanding high-risk automation.

Trust and responsible AI

Good answers need relevant evidence. Safe actions need current authority. Uncertainty should remain visible instead of being converted into apparent success.

Approved-source policy answers

IMPLEMENTED

The Policy Assistant uses approved, dated, audience-authorized material. Its constrained selection validates the allowed extract and exact quotation, rather than accepting arbitrary invented citations. Insufficient, conflicting or unsafe material can prevent an answer.

Recorded-evidence case explanations

IMPLEMENTED

Case explanations describe available recorded evidence, not hidden model reasoning. Missing facts should be reported as not established. Model output is not proof of eligibility, authenticity or professional approval.

Approval, readiness and audit controls

IMPLEMENTED

Recorded approvals, readiness gates and tamper-evident audit records support traceability. A checklist score or completed execution attempt does not by itself prove business completion.

Independent audit assurance

CONFIGURATION REQUIRED

The protected-audit framework has provider-verification and launch-drill gates. Independent assurance requires the client's approved provider, current verified checkpoints and successful drills. A local hash chain alone is not independent proof.

Business example
For 'Why is onboarding blocked?', the app should identify recorded missing evidence or approval. For a leave-policy question, it should cite applicable approved material or explain that an answer cannot be established; a confident guess is not sufficient.

Roadmap - answer quality: Business-approved benchmark questions, broader claim-to-source validation across answer types, systematic model-change evaluations and more deterministic eligibility/deadline rules.

Roadmap - fairness: A dedicated fairness evaluation programme and AI-decision appeal process. Use reviewed, job-relevant criteria, synthetic paired tests and lawfully governed outcome analysis. Human review alone does not eliminate bias.

Document authenticity and Employee Vault

A readable, malware-safe file can still be forged. Authenticity needs trustworthy source evidence tied to the correct person and exact document version.

Independent employee ownership and consent

IMPLEMENTED

Employee Vault is a separate employee-owned application. Registration does not grant employer membership or reviewer authority. Employer sharing requires explicit consent, scope, current requirements, freshness and case binding.

Signed, version-bound verification controls

IMPLEMENTED

The Vault checks signed source results against approved issuer configuration and binds results to document revisions and content hashes. A changed, expired or no-longer-valid binding is not treated as current verification. This framework is not proof that every document type has a connected verification service.

Live issuer and verification connections

CONFIGURATION REQUIRED

Real verification requires an approved issuer or provider, supported check types and jurisdictions, and authenticated source results. No unspecified commercial provider should be represented as a working integration.

Business example
An employee uploads a degree certificate. Extracting the name and degree is not verification. An approved source must confirm the relevant record and person match; the result must remain bound to the submitted document version.

Business example
An employer requires identity, education and employment checks. A clear identity result alone does not mean full background verification. The employee can withdraw future sharing authority, but an earlier lawful disclosure is not retroactively undone.

Broader authenticity coverage

ROADMAP

Add and validate selected live issuer/provider adapters, strengthen identity matching where legally appropriate, and extend revocation/freshness checks for the chosen sources. Source-verified, unavailable, uncertain and adverse results must remain distinct.

Business features and the improvement roadmap

Current work management is separate from the additional assurance work proposed below. Roadmap items are not described as available features.

Implemented business area	Illustrative use
Cases, approvals and Action Center	Assign an unresolved task to a named owner and track review, evidence and follow-up.
Onboarding and workforce operations	Coordinate documents, Day-1 logistics, early-tenure checks, frontline requirements and transfer cutover sign-offs.
Policies, systems and communications	Review policy revisions; monitor configured connectors and communication channels. A connector's presence does not establish live provider readiness.
Analytics and Cost-Benefit Explorer	Review bottlenecks and compare costs or scenarios using visible assumptions. Estimates are not proven savings or causal outcome forecasts.

Priority roadmap - additional assurance

Area	Additional work / roadmap	Business outcome sought
Compliance	Consolidated obligation-to-control coverage, evidence packs and periodic independent assessment.	Show which requirements are satisfied, by whom, and with what evidence.
Authenticity	Selected live verification adapters and broader source-backed check coverage.	Distinguish a genuine source result from a plausible uploaded file.
Answer quality	Systematic business benchmarks, expanded claim checks and deterministic rules.	Measure correctness and stop unsupported answers.
Fairness	Governed paired tests, lawful disparity analysis and an independent appeal process.	Detect unequal treatment and provide meaningful review.

Where users find the controls

Control Tower: Cases, Approvals, Action Center, Policy Assistant, policy library, Audit, Systems and UAT Test Center. **Settings:** access governance, privacy policies, unified context history and reviewed retention. **Separate apps:** Employee Vault and the Cost-Benefit Explorer. Visibility is permission-dependent.

Bottom line: Controls require approved configuration, connected sources, ongoing tests and independent review. They do not guarantee compliance, universal authenticity, correct AI answers or bias-free decisions.